

GreenLeaf E-Commerce – Data Classification Policy

Document Owner: Cameron Naidoo
Effective Date: 29 June 2026
Review Cycle: Annually
Classification: Internal / Confidential
Version: 1.0

1. Purpose

The purpose of this policy is to establish a framework for classifying data based on its sensitivity, value, and criticality to GreenLeaf E-Commerce. Proper classification ensures that data is protected with appropriate security controls and handled consistently across the organization.

2. Scope

This policy applies to all **Employees, Contractors, Interns, and Third-Party Vendors** who create, access, store, transmit, or dispose of data on behalf of GreenLeaf. It covers all data formats, including electronic files, paper documents, and verbal communications.

3. Data Classification Levels

GreenLeaf classifies data into **four levels**. Each level requires a different set of security controls.

Level	Description	Examples	Handling Requirements
Public	Information that is approved for public release. No harm to GreenLeaf if disclosed.	Marketing materials, public website content, press releases.	No special protection required. Can be shared freely.
Internal	Information that is not public but would not cause significant harm if disclosed. Limited to employees and authorized contractors.	Internal memos, employee handbooks, non-sensitive operational data.	Must be protected from unauthorized access. Can be shared within the organization.
Confidential	Information that would cause moderate harm to GreenLeaf if disclosed. Requires strict access controls.	Customer contact lists, pricing strategies, financial forecasts.	Access limited to those with a business need. Must be encrypted at rest and in transit.
Restricted	Information that would cause severe harm to GreenLeaf or its customers if disclosed.	Customer PII (names, addresses, payment details), employee bank details, legal documents, passwords.	Access strictly limited to authorized personnel. Must be encrypted at rest and in transit. MFA required for access. Data retention and disposal must follow strict guidelines.

4. Data Classification by Role

Data classification is the responsibility of the **Data Owner**—the person who creates or controls the data.

Role	Responsibility
Data Owner	Classifies data according to this policy. Reviews classification annually. Approves access requests.
Data Custodian	Implements and maintains the security controls (e.g., IT team manages encryption and backups).
Data User	Handles data in accordance with its classification level. Reports any suspected data breaches.

5. Handling Requirements by Classification Level

Requirement	Public	Internal	Confidential	Restricted
Access Control	None	Limited to employees	Business need required	Strictly authorized personnel only
Encryption (at rest)	Not required	Not required	Required	Required
Encryption (in transit)	Not required	Recommended	Required	Required
MFA Required	No	No	Yes	Yes
Data Retention	As per business needs	As per business needs	7 years (or as required by law)	7 years (or as required by law)
Disposal	Standard deletion	Secure deletion (e.g., recycle bin clearing)	Secure deletion (e.g., file shredder)	Secure deletion (e.g., DoD-level wipe)
Breach Notification	Not required	Not required	Required	Required

6. Classification Examples (GreenLeaf-Specific)

Data Type	Classification	Justification
GreenLeaf public website content	Public	Approved for public release.
Employee onboarding handbooks	Internal	Not public, but low sensitivity.
Customer names and email addresses	Confidential	Could cause reputational damage if leaked.
Customer credit card numbers	Restricted	Financial fraud risk. Requires highest protection.
Employee bank account details	Restricted	Payroll fraud risk. Requires highest protection.
Internal financial forecasts	Confidential	Could harm competitive position if leaked.

7. Reclassification & Review

Data classification must be reviewed:

- **Annually** by the Data Owner.
- **Immediately** if the data's sensitivity changes (e.g., a product goes from "pre-release" to "public").
- Following a security incident involving that data.

8. Compliance & Enforcement

Non-compliance with this policy may result in disciplinary action, up to and including termination of employment or contract. Compliance will be verified through periodic audits and spot checks.

9. Review Cycle

This policy shall be reviewed annually or immediately following a major data breach incident.